
PCI DSS v4.0.1 SAQ A GAP ANALYSIS

Willowmere Home & Living

A 22 Control Self Assessment Against PCI DSS v4.0.1

Prepared by: Reward Oladejo-Olagboye

Report date: 16 September 2026

Standard Referenced: PCI DSS v4.0.1, Self Assessment Questionnaire A

Classification: Confidential, Internal Distribution Only

Note: Willowmere Home & Living is a fictional organisation created for the purpose of demonstrating a structured PCI DSS gap analysis methodology.

Document Control

Field	Detail
Document Title	PCI DSS v4.0.1 SAQ A Gap Analysis
Organisation	Willowmere Home & Living (fictional)
Version	1.0
Author	Reward Oladejo-Olagboye
Date	16 September 2026
Standard Referenced	PCI DSS v4.0.1, SAQ A
Classification	Confidential

Table of Contents

For Leadership: What You Need to Know 4

1. Purpose and Scope 4

2. SAQ Eligibility Determination 4

3. Methodology 5

4. Gap Analysis 6

5. Key Findings: Priority Gaps 8

6. Remediation Roadmap 9

7. Conclusion 9

Appendix A: SAQ A Eligibility Criteria 10

Appendix B: Payment Page Script Inventory 11

Appendix C: Sample Technical Configuration 12

Appendix D: Glossary..... 13

For Leadership: What You Need to Know

We reviewed how our online store handles card payments against PCI DSS, the security standard every card processor requires merchants to follow.

The good news first. Because all card payments are handled through Stripe's hosted checkout, customer card numbers never touch our own systems. That single decision already removes most of the risk a typical online retailer carries.

The area that needs attention is newer, and it catches a lot of businesses out. Small pieces of code on our checkout page, things like analytics tools and chat widgets, aren't currently tracked or monitored the way the rules now require. Attackers have started targeting exactly this kind of unmonitored code to quietly steal card details as customers type them in, without ever breaking into a company's actual servers.

None of this requires us to start storing card data ourselves or rebuild the checkout page. It comes down to two practical things: keeping a clear, up to date list of every piece of code running on that page and making sure one named person is responsible for checking it stays that way. Both are achievable within the next few months, at low cost, and without any disruption to the checkout experience customers see.

1. Purpose and Scope

This document assesses Willowmere Home & Living's compliance with PCI DSS v4.0.1, using Self-Assessment Questionnaire A, the applicable questionnaire for merchants who have fully outsourced cardholder data handling to a validated third party.

This assessment covers the checkout page and its supporting infrastructure, the scripts and third-party services loaded on that page, administrative access to systems capable of affecting it, and Willowmere's governance processes around payment card security. It does not cover systems unrelated to the payment flow, such as internal HR or warehouse management tools.

2. SAQ Eligibility Determination

Before completing a self assessment, a merchant must confirm which SAQ type actually applies. Using the wrong one, most commonly assuming SAQ A when SAQ A-EP is required, is a common and serious error. Willowmere's eligibility for SAQ A rests on the following:

- All card payment capture is handled by Stripe Checkout, a fully hosted, PCI DSS validated redirect page.
- Willowmere's own servers never receive, transmit, process or store cardholder data in any form.
- Customers are redirected to Stripe's hosted page to enter card details; no card data is captured on any page Willowmere hosts or controls.
- The only elements within Willowmere's control are the page that initiates the redirect and the scripts loaded on it, which is precisely why the newer script security controls in this assessment apply.

On this basis, Willowmere correctly qualifies for SAQ A rather than SAQ A-EP or SAQ D. This determination should be confirmed again annually, since any change to the checkout flow, such as adopting an embedded card field instead of a redirect, could shift Willowmere into a different SAQ category.

3. Methodology

Willowmere's current practices were assessed against all 22 requirements set out in PCI DSS v4.0.1 SAQ A. This included a live audit of the checkout page using browser developer tools to identify every script loading on it, a review of administrative access across the CMS, CDN and DNS providers, and discussion with the team responsible for day to day website operations.

Each control was rated using a RAG scale. Green indicates the requirement is fully met with evidence available. Amber indicates partial coverage or evidence that is incomplete or outdated. Red indicates the requirement is not currently met.

SAQ A's 22 requirements split into two groups. Six are long standing requirements largely unchanged since earlier versions of the standard, covering account data protection, encryption, physical access, and basic policy and provider management. The remaining sixteen were introduced or expanded under PCI DSS v4.0.1 and concentrate heavily on payment page script security and governance discipline, a direct response to the rise of skimming attacks against outsourced checkout pages.

4. Gap Analysis

All 22 SAQ A requirements are set out below, RAG rated against Willowmere's current practice.

No.	PCI Req.	Control	Current State	RAG	Remediation
1	Req 3	Account Data Protection	No cardholder data is stored on Willowmere's systems; policy confirms this and is reviewed annually.	Green	No action required; maintain current policy and annual review.
2	Req 4	Transmission Encryption	Checkout page and Stripe hosted page both enforce TLS 1.3, confirmed via SSL Labs scan.	Green	No action required; retest annually.
3	Req 2	Vendor Default Credentials	CMS and hosting admin accounts use unique passwords; CDN console still uses a default recovery contact set at initial deployment.	Amber	Update CDN console recovery contact and confirm no default credentials remain on any admin interface.
4	Req 9	Physical Access to Cardholder Data	Willowmere does not accept card details by phone, post or in person; no physical cardholder data is ever received.	Green	No action required; retain written confirmation of this scope exclusion.
5	Req 12.1	Information Security Policy	A written information security policy exists but was last reviewed over two years ago.	Amber	Review and reissue the policy, then schedule a mandatory annual review date.
6	Req 12.8	Service Provider Management	A list of service providers exists, but current signed Attestations of Compliance have not been collected from all of them.	Red	Request current AOCs from Stripe, the CDN provider, and the analytics and chat vendors; set an annual renewal reminder.
7	Req 12.1.2	Named Roles and Responsibilities	PCI related tasks are handled informally by "the IT team" with no single named owner.	Red	Assign a specific named role, for example Compliance Lead, as owner of each PCI related task.
8	Req 12.3.1	Targeted Risk Analyses	No targeted risk analysis has been documented for any control where the standard allows flexible frequency.	Red	Document a short risk based justification for review frequencies chosen, starting with policy review and provider AOC checks.
9	Req 12.6	Security Awareness Training	Staff receive informal guidance on phishing and password hygiene, but no training records are kept.	Amber	Move to a tracked annual training programme with completion records for all staff with PCI relevant access.
10	Req 12.10	Incident Response Plan	A general company incident response plan exists but has not been tested against a payment specific breach scenario.	Amber	Run a tabletop exercise simulating a payment data incident and update the plan based on findings.
11	Req 6.4.3	Payment Page Script Inventory	No formal inventory of scripts loading on the checkout page has been created; analytics, chat and marketing scripts are not documented.	Red	Audit the live checkout page and build a script inventory covering source, purpose, owner and review date for every script.
12	Req 11.6.1	Script Tamper Detection	No Content Security Policy or automated tamper detection is deployed on the checkout page.	Red	Deploy a Content Security Policy with Subresource Integrity hashes, or a dedicated tamper detection service, on the checkout page.
13	Req 6.3.1	Vulnerability Identification for Scripts	No process exists to monitor third party scripts on the checkout page for known vulnerabilities.	Red	Subscribe to a vulnerability feed and assign responsibility for triaging issues affecting checkout page components.
14	Req 6 (practice)	Script Bill of Materials	No record is kept of script versions loaded on the checkout page.	Red	Maintain a simple version log for every script and library loaded on the checkout page.
15	Req 8.4.2	Multi Factor Authentication	MFA is enforced on the CMS admin panel, but not on the CDN console or DNS provider account.	Amber	Extend MFA to every admin interface capable of affecting the checkout page, including CDN and DNS.

No.	PCI Req.	Control	Current State	RAG	Remediation
16	Req 8.2.1	Unique User IDs	Every staff member with PCI relevant access has an individual account; no shared logins were found.	Green	No action required; retain this practice.
17	Req 8.3.4	Account Lockout	Accounts lock after 10 failed login attempts with a 30 minute minimum lockout, in line with requirement.	Green	No action required.
18	Req 8.3.6	Password Length and Complexity	The CMS enforces a 12 character minimum. A legacy invoicing tool still enforces an 8 character limit.	Amber	Upgrade or replace the legacy invoicing tool, or formally document that it has no access to payment related infrastructure.
19	Req 8.2.8	Session Timeout	Admin sessions on the CMS time out after 15 minutes of inactivity.	Green	No action required.
20	Req 11.4	Provider Penetration Testing	Stripe's Attestation of Compliance and penetration testing summary are obtained and filed annually.	Green	No action required; continue annual collection.
21	Req 12.11	Annual SAQ and AOC Submission	Last year's SAQ was completed and submitted, but later than intended, with no calendar reminder in place.	Amber	Set a recurring calendar reminder eleven months out from the last submission date.
22	Req 6.5.1	Change Management for Payment Pages	Changes to the checkout page can be made directly by developers with no formal review or sign off process.	Red	Introduce a documented change management process requiring review and sign off for any change to the checkout page or its scripts.

5. Key Findings: Priority Gaps

The six gaps below carry the greatest practical risk and are examined in more detail.

Control 11: Payment Page Script Inventory

Current State: No formal inventory exists of the scripts running on Willowmere's checkout page. Analytics, live chat, and marketing pixels are loaded without documentation of source, purpose, or ownership.

Why This Matters: This is the single most common failure point for SAQ A merchants under PCI DSS v4.0.1, and for good reason. Attackers no longer try to breach a merchant's servers directly, they compromise a third party script that already has legitimate access to the checkout page, and use it to silently capture card details as customers type them. A merchant cannot detect or respond to this if it does not even know which scripts are running.

Recommended Action: Audit the live checkout page using browser developer tools, list every script by source and purpose, assign a business owner to each, and review the list on a recurring schedule. See Appendix B for the completed inventory.

Control 12: Script Tamper Detection

Current State: No Content Security Policy or automated tamper detection mechanism is deployed on the checkout page.

Why This Matters: This control exists specifically to catch the attack described above, unauthorised changes to scripts or page content. Without it, a compromised script could run for months before anyone notices, since nothing on the page changes visibly. PCI DSS v4.0.1 makes this mandatory, not optional, and assessors will not accept manual monitoring as a substitute.

Recommended Action: Deploy a Content Security Policy with Subresource Integrity hashes for every script, or adopt a dedicated tamper detection service, with alerts routed to a named owner. See Appendix C for a sample configuration.

Control 7: Named Roles and Responsibilities

Current State: PCI related tasks currently sit with "the IT team" as a general concept, rather than a specific named person or role.

Why This Matters: Diffuse ownership is how controls quietly lapse. When no single person is accountable for a task, for example checking a provider's Attestation of Compliance has been renewed, it becomes easy for that task to simply not happen, and for nobody to notice until an assessment surfaces the gap.

Recommended Action: Assign a specific named role, for example a Compliance Lead, as the accountable owner for each PCI related task, and update the assignment whenever staff change.

Control 6: Service Provider Management

Current State: A list of service providers exists, but current Attestations of Compliance have not been collected from all of them.

Why This Matters: Outsourcing card capture to Stripe is what makes SAQ A eligibility possible in the first place. That protection only holds if every provider touching the payment flow, including the CDN and any analytics or chat vendor with checkout page access, can demonstrate their own PCI compliance. An expired or missing AOC is a gap in the foundation the whole SAQ A eligibility rests on.

Recommended Action: Request current AOCs from every listed provider, and set an annual renewal reminder well ahead of each expiry date.

Control 8: Targeted Risk Analyses

Current State: No targeted risk analysis has been documented for controls where PCI DSS allows flexibility in review frequency.

Why This Matters: This is a newer, purely governance focused requirement under v4.0.1. It does not ask for a different control, it asks Willowmere to show its reasoning for the frequency choices it has already made, for

example, why an annual policy review is sufficient rather than a quarterly one. Without this written justification, an otherwise reasonable practice reads as arbitrary to an assessor.

Recommended Action: Write a short, risk based justification for each flexible frequency control, starting with policy review and provider AOC checks.

Control 22: Change Management for Payment Pages

Current State: Developers can currently push changes to the checkout page directly, with no formal review or sign off step.

Why This Matters: Most real world Magecart style attacks succeed through exactly this gap, a small, unreviewed change to a script tag that nobody else looked at before it went live. A change management process is the most direct, practical defence against this specific attack pattern, more so than any monitoring tool alone.

Recommended Action: Introduce a documented change process requiring review and sign off before any change to the checkout page or its scripts is deployed.

6. Remediation Roadmap

6.1 Immediate (0 to 30 Days)

- Assign a named Compliance Lead role for all PCI related tasks (Control 7).
- Audit the live checkout page and build a full script inventory (Control 11).
- Request current Attestations of Compliance from all service providers (Control 6).

6.2 Short Term (30 to 90 Days)

- Deploy a Content Security Policy and script tamper detection on the checkout page (Control 12).
- Extend multi factor authentication to the CDN console and DNS provider account (Control 15).
- Introduce a documented change management process for the checkout page (Control 22).
- Document targeted risk analyses for all flexible frequency controls (Control 8).

6.3 Ongoing (90 Days and Beyond)

- Subscribe to a vulnerability feed covering checkout page components (Control 13).
- Maintain a version log for all checkout page scripts and libraries (Control 14).
- Replace or formally exclude the legacy invoicing tool from PCI scope (Control 18).
- Move to a tracked annual security awareness training programme (Control 9).
- Calendar annual reviews for the information security policy and SAQ submission (Controls 5, 21).

7. Conclusion

Willowmere's decision to fully outsource card capture to Stripe has already eliminated the largest categories of PCI risk a merchant can carry. The gaps identified here are concentrated almost entirely in the newer script security and governance requirements introduced by PCI DSS v4.0.1, rather than in the foundational controls, which are largely in good order.

None of the identified gaps require storing cardholder data or rebuilding the checkout flow. They require closer tracking of code already running on the payment page and clearer, named ownership of a small number of recurring compliance tasks. The remediation roadmap above is achievable within a single quarter with modest effort.

Appendix A: SAQ A Eligibility Criteria

A merchant qualifies for SAQ A only where all of the following are true: all cardholder data functions are outsourced to a PCI DSS validated third party, the merchant's systems never store, process or transmit cardholder data, and the payment page is either a full redirect to the processor or an iframe the merchant does not control. Any deviation from these conditions, such as capturing card data directly on a merchant hosted page, moves the merchant into SAQ A-EP or SAQ D instead.

Appendix B: Payment Page Script Inventory

The inventory below satisfies Control 11 (Requirement 6.4.3), covering every script identified on Willowmere's checkout page as of the date of this assessment. It should be treated as a living document, reviewed whenever a script is added, removed, or changed.

No.	Script / Vendor	Source Domain	Loads on Checkout	Integrity Monitored	Status	Remediation Note
1	Stripe Checkout.js	js.stripe.com	Yes	Yes, by Stripe	Green	No action required, provider validated.
2	Google Analytics (gtag.js)	googletagmanager.com	Yes, on confirmation page	No	Red	Add to CSP allowlist and enable SRI hash.
3	Meta Pixel	connect.facebook.net	Yes, on confirmation page	No	Red	Add to CSP allowlist and enable SRI hash.
4	Klaviyo	static.klaviyo.com	Yes	No	Red	Add to CSP allowlist and enable SRI hash.
5	Intercom Chat Widget	widget.intercom.io	Yes, site wide	No	Red	Highest priority, broad page access; review necessity on checkout page.
6	Hotjar	script.hotjar.com	Yes	No	Red	Highest priority, can capture page input; consider removing from checkout page.
7	Cloudflare CDN	cdnjs.cloudflare.com	Indirect, serves other scripts	Partial, via CDN provider	Amber	Confirm CDN provider integrity settings are documented.
8	jQuery (self-hosted)	willowmerehome.co.uk/assets	Yes	No, version not tracked	Red	Add to script bill of materials and track version.

Appendix C: Sample Technical Configuration (Controls 11 and 12)

The examples below illustrate the type of technical configuration that would close Controls 11 and 12, read alongside the governance record maintained in Appendix B, the payment page script inventory.

C.1 Content Security Policy Header

A Content Security Policy restricts which domains are allowed to load scripts on the checkout page, so an unauthorised or injected script is blocked by the browser rather than silently executing.

```
Content-Security-Policy:
  default-src 'self';
  script-src 'self' js.stripe.com googletagmanager.com
    static.klaviyo.com widget.intercom.io;
  report-uri /csp-violation-report;
```

C.2 Subresource Integrity

Subresource Integrity adds a cryptographic hash to a script tag, so the browser refuses to run that script if its content has been altered from what was expected.

```
<script src="https://cdnjs.cloudflare.com/ajax/libs/jquery/3.7.1/jquery.min.js"
  integrity="sha384-EXAMPLEHASHVALUEDONOTUSEINPRODUCTIONabcXYZ"
  crossorigin="anonymous"></script>
```

Willowmere does not currently have either control in place, this is the substance of Control 12's gap. Deploying this configuration, together with the completed script inventory in Appendix B, would close the two highest priority findings in this assessment.

Appendix D: Glossary

PCI DSS: Payment Card Industry Data Security Standard, the contractual security standard maintained by the major card brands for any business handling card data

SAQ: Self Assessment Questionnaire, the mechanism by which a merchant attests to its own compliance with the applicable subset of PCI DSS requirements

AOC: Attestation of Compliance, the signed document confirming a service provider or merchant has completed its PCI DSS assessment

CDE: Cardholder Data Environment, the people, processes and technology that store, process or transmit cardholder data

CSP: Content Security Policy, a browser level control that restricts which scripts are allowed to run on a web page

Magecart: A category of attack in which malicious code is injected into a checkout page to silently capture card details as customers enter them

PAN: Primary Account Number, the full card number embossed on a payment card